

Grana.

Auditoria de segurança · 02/09/2026 · America/Sao_Paulo
Commit analisado: 4b5015223196c79b9e15c449efbd7f524109e23c

Cinco riscos de segurança e integridade encontrados na superfície Supabase/Expo, com evidência rastreável e correção recomendada.

Veredito. O isolamento por locatário, RLS e os handlers privilegiados apresentam boas barreiras no código atual. Os bloqueadores desta rodada estão em credenciais de webhook, tokens de ativação no cliente, garantia de reautenticação para exclusão e confiança excessiva em estado de gamificação.

5	2	2	0
ACHADOS	ALTA	MÉDIA	XSS CONFIRMADO

Escopo: isolamento por locatário e RLS · autorização server-side versus gates de frontend · IDOR em RPCs e Edge Functions · segredos no código, histórico e bundle · XSS, HTML e sinks de entrada.

O que foi verificado

Revisão somente leitura do repositório local; nenhum build, deploy, migração ou escrita em produção foi disparado.

86

ARQUIVOS

3

EDGE FUNCTIONS

18

TABELAS COM RLS

0

TESTES MUTÁVEIS

Critérios

- Tenant isolation: auth.uid(), USING, WITH CHECK, FKs compostas e joins.
- Autorização: gates da UI comparados com RPCs/Edge Functions.
- IDOR: todos os parâmetros UUID/telefone/evento rastreados até o filtro de dono.
- Segredos: fontes atuais, histórico Git e bundle dist escaneados sem imprimir valores.
- XSS: HTML, CSS inline, document.write, SVG e templates de relatório.

Resultado por categoria

Tenant: sem brecha confirmada

IDOR: sem brecha confirmada

XSS: sem XSS confirmado

Integridade: 1 risco

Nota de confiança. F-001 e F-004 dependem de estado externo que não está versionado. Eles são riscos de garantia/control-plane, não alegações de exploração confirmada em produção.

Prioridade de correção

A severidade considera impacto, facilidade e dependências externas; a confiança separa prova no código de hipótese condicional.

ID	ACHADO	SEVERIDADE	CONFIANÇA
GRN-SEC-001	Exclusão de conta depende de uma garantia de reautenticação que está só no cliente	ALTA	Média / lacuna verificável no repositório
GRN-SEC-002	Webhook Kiwify autentica com bearer estático em URL e corpo	ALTA	Alta
GRN-SEC-003	Token de ativação permanece exposto no cliente antes do consumo	MÉDIA	Alta
GRN-SEC-004	Vínculo automático de assinatura não exige e-mail confirmado	MÉDIA	Condicional
GRN-SEC-005	Conquistas são graváveis pelo próprio cliente sem allowlist	BAIXA	Alta

Leitura executiva

Primeiro: retire o bearer da URL/corpo da Kiwify e faça a função de exclusão existir em código versionado com step-up server-side. **Depois:** elimine o token de ativação do armazenamento persistente cru, imponha e-mail confirmado no vínculo automático e torne conquistas somente leitura para o cliente.

Controles positivos

- RLS habilitado nas 18 tabelas identificadas; policies financeiras finais combinam `auth.uid() = user_id` com `tem_direito_acesso()`.
- Nenhum IDOR ou quebra de tenant foi confirmado na revisão estática: RPCs por UUID filtram também `user_id` e FKs compostas reforçam relações de mesmo dono.
- RPCs administrativas e de webhook revogam EXECUTE de `public/anon/authenticated` e concedem somente a `service_role`.
- HMAC de WhatsApp e EAS falha fechado quando o `secret` falta; comparação é constante e o corpo tem limite de tamanho.
- Os sinks HTML revisados usam conteúdo estático ou `escaparHtml` para descrições, categorias e nomes; não foi confirmado XSS executável.
- Busca de segredos atuais/históricos não encontrou `PAT sbp_`, `service_role` hard-coded, chaves privadas, GitHub token ou chaves OpenAI/Groq; JWTs encontrados são `anon` e públicos.

Riscos que atravessam a fronteira de confiança

GRN-SEC-001 ALTA

Média / lacuna verificável no repositório

Exclusão de conta depende de uma garantia de reautenticação que está só no cliente

Risco condicional não verificável em produção

Impacto. A tela pede a senha via `signInWithPassword` e depois chama a Edge Function `delete-account`. Essa função não existe no repositório; portanto não há evidência auditável de que o servidor exija uma credencial recém-validada. Se o endpoint aceitar somente o JWT de sessão, qualquer sessão roubada pode apagar a conta sem a senha.

Evidência. `app/(app)/perfil.tsx:178-194` · `lib/data.ts:783-809` · `supabase/schema.sql:3195-3198` · `supabase/functions/`: sem `delete-account`

Correção. Implementar a Edge Function em código versionado; validar JWT, `user_id` derivado do token e reautenticação recente (ou step-up token de uso único) no servidor; testar chamada direta sem passar pela UI.

GRN-SEC-002 ALTA

Alta

Webhook Kiwify autentica com bearer estático em URL e corpo

Confirmado no código

Impacto. O segredo é aceito em `x-kiwify-token`, `webhook_token`, `token`, `secret` ou `?token=`. Query strings aparecem em histórico, proxies e logs; corpo/headers podem ser retidos por observabilidade. Com o bearer vazado, um atacante consegue fabricar novo `event_id` e evento `approved` para liberar uma assinatura própria.

Evidência. `supabase/functions/kiwify-webhook/index.ts:20-32` · `supabase/functions/kiwify-webhook/index.ts:73-95` · `supabase/schema.sql:3054-3193`

Correção. Remover token de query/body; aceitar apenas HMAC da requisição bruta ou o cabeçalho oficial documentado; rotacionar o segredo atual, rejeitar replay por timestamp/nonce e manter inbox idempotente.

Token de ativação permanece exposto no cliente antes do consumo

Confirmado no código

Impacto. O link /ativar?token=... coloca um bearer na URL e, quando a pessoa está deslogada, o app o copia para AsyncStorage (localStorage na web). O servidor agora usa hash, expiração e consumo único, mas uma cópia local pode sobreviver indefinidamente e ser lida por backup, extensão/XSS ou dispositivo comprometido.

Evidência. app/ativar.tsx:39-48 · lib/assinatura.ts:1-18 · supabase/schema.sql:1364-1394

Correção. Usar SecureStore no nativo e memória/sessionStorage com TTL curto na web; remover token também em erro/expiração; trocar links por fragmento ou código de uso único que não viaje em Referer/logs.

Riscos condicionais e de estado

GRN-SEC-004 MÉDIA

Condicional

Vínculo automático de assinatura não exige e-mail confirmado

Risco dependente da configuração de Auth

Impacto. vincular_assinatura_automatica associa qualquer assinatura sem user_id ao e-mail da sessão. Se a confirmação de e-mail estiver desativada ou houver um provedor que emita sessão antes da verificação, basta cadastrar o e-mail de uma compra para receber o acesso pago.

Evidência. supabase/schema.sql:2351-2378 · supabase/schema.sql:2364-2373 · lib/auth-context.tsx:75-90

Correção. No servidor, exigir auth.users.email_confirmed_at não nulo (ou identidade verificada equivalente) antes da associação; confirmar a configuração de confirmação de e-mail em produção e criar teste negativo.

GRN-SEC-005 BAIXA

Alta

Conquistas são graváveis pelo próprio cliente sem allowlist

Confirmado como risco de integridade

Impacto. A policy FOR ALL permite INSERT/UPDATE/DELETE em user_achievements quando user_id é próprio, sem validar badge_id ou unlocked_at. Um usuário autenticado pode fabricar qualquer medalha e data; isso não atravessa RLS nem libera dados financeiros, mas falsifica o estado de gamificação.

Evidência. supabase/schema.sql:3237-3252 · lib/data.ts:426-440

Correção. Conceder ao app apenas SELECT próprio; mover desbloqueio para RPC server-side com allowlist de badge_id, regras derivadas de dados e timestamps do banco.

Limitações e próximos testes

- Não foram feitas chamadas REST/RPC de escrita ou testes contra contas reais; a matriz A→B estática prevê bloqueio, mas não o prova no catálogo implantado.
- A Edge Function delete-account não está versionada; o comportamento do endpoint eventualmente implantado não pôde ser validado.
- Não foi disparado build, deploy ou migração; não houve geração de bundle novo. O diretório dist existente foi apenas escaneado.
- Configurações externas de confirmação de e-mail, retenção de logs e segredo oficial da Kiwify precisam ser confirmadas no painel sem expor valores.

Fechamento

Sequência sugerida em staging: (1) HMAC/header-only e rotação da Kiwify; (2) Edge Function de exclusão com step-up; (3) SecureStore/sessionStorage e limpeza de tokens; (4) confirmação de e-mail no RPC; (5) RPC de conquistas com allowlist; (6) testes negativos RLS/IDOR com dois usuários.

Controles que devem permanecer

- RLS habilitado nas 18 tabelas identificadas; policies financeiras finais combinam `auth.uid() = user_id` com `tem_direito_acesso()`.
- Nenhum IDOR ou quebra de tenant foi confirmado na revisão estática: RPCs por UUID filtram também `user_id` e FKs compostas reforçam relações de mesmo dono.
- RPCs administrativas e de webhook revogam EXECUTE de public/anon/authenticated e concedem somente a `service_role`.
- HMAC de WhatsApp e EAS falha fechado quando o secret falta; comparação é constante e o corpo tem limite de tamanho.
- Os sinks HTML revisados usam conteúdo estático ou `escaparHtml` para descrições, categorias e nomes; não foi confirmado XSS executável.
- Busca de segredos atuais/históricos não encontrou PAT `sbp_`, `service_role` hard-coded, chaves privadas, GitHub token ou chaves OpenAI/Groq; JWTs encontrados são anon e públicos.

Fontes primárias

- [Supabase — Securing your API](#)
- [Supabase — Row Level Security](#)
- [Supabase — Secure data](#)
- [Expo SDK 57 reference](#)

O bundle dist contém somente JWTs com claim de role anon e a chave pública correspondente ao projeto; valores foram omitidos deste documento. Nenhum token PAT fornecido para operações Supabase foi usado ou reproduzido no relatório.